

domain 1 and 3 are important

17-19 detailed audit

3.1 ITGC Audit planning and preparation

Checking resource : check on available resource to conduct testing

Internal meeting within department and request for approval : updating the understanding and communication and the requirements to the team and request for the approval within internal .

Engagement preparation :

- Structure the testing control
- Project plan and scope
- Resource allocation
- Time frame and budget plan
- Team briefing & role assignment

Working paper and file preparation :

- Importing testing control
- Planning the audit response
- Planning ITGC involvement
- Working paper format

Client communication :

- Preparing list required information to client
- Preparing the kick off meeting with client to discuss the overall IT environment understanding
- Draw and confirm system architecture with client
- Communicating the agreed date of the fieldwork
- Prepare list request document for client

3.1. ITGC Audit Planning & Preparation



3.2. ITGC Audit Fieldwork Execution and Review

First Day of fieldwork execution

- Checking the available document
- Updating any remaining document
- Executing the task based on existing document

Significant Risk Identification

- Being able to identify any significant risk

- Communicating the significant risk with In-charge & line-manager

Execution

- Further testing for remaining controls
- Documenting the working result

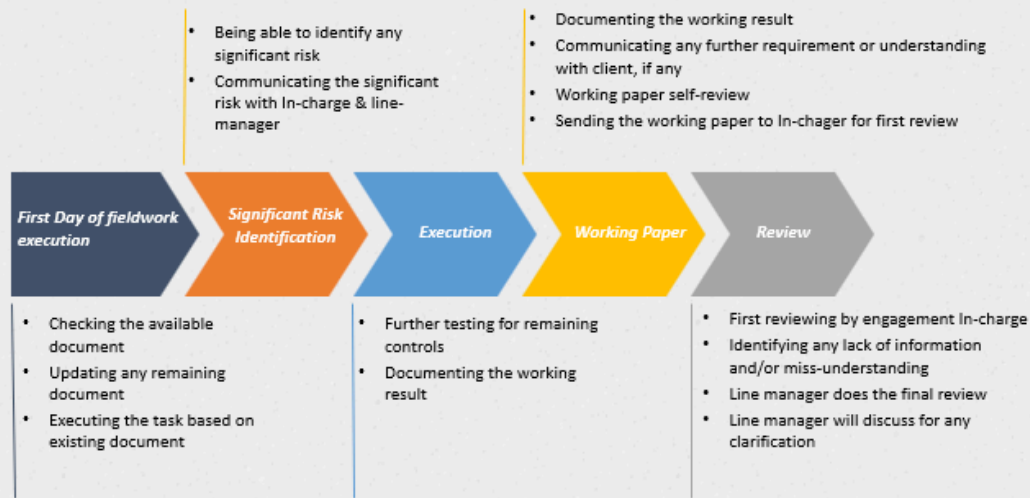
Working Paper

- Documenting the working result
- Communicating any further requirement or understanding with client, if any
- Working paper self-review
- Sending the working paper to In-charge for first review

Review

- First reviewing by engagement In-charge
- Identifying any lack of information and/or miss-understanding
- Line manager does the final review
- Line manager will discuss for any clarification

3.2. ITGC Audit Fieldwork Execution and Review



3.3. IT Audit Reporting

ITGC internal Report wrap-up

- Concludes the audit result
- Confirm with team members

Internal meeting between ITGC team over the result

- ITGC team are joining the internal meeting to discuss on the audit result with recommendation

Management Letter, if any

- Drafting the management letter if there is any finding
- Line manager does the review on the management letter and send out to client for management response

ITGC Audit Finding Presentation

- Arranging the Exit-meeting with client (Head of IT department and relevant department) to present the ITGC audit finding

Close Engagement & Performance Feedback

- Evaluating and confirming ML response from client
- Closing the engagement including aura file (only ITGC section)
- Doing the performance feedback with Line manager (only 40h up) as performance benefit

3.3. IT Audit Reporting



ITGC



4. ITGC

4.2. Risks arising from IT

Access to programs and data (APD)

- Unauthorized access to systems by business users
- Unauthorized access to systems and data by IT users
- Unauthorized changes to data

Program development (PD)

- Newly implemented applications inaccurately process data, due to coding or configuration issues
- Errors in migrating transaction records and/or master files

Program Change (PC)

- Failure to make necessary changes to systems or programs
- Changes that introduce errors into applications
- Unauthorized direct changes to application code
- Unauthorized direct changes to application configuration settings
- Updates to the IT environment prevent applications from running correctly

Computer Operations (CO)

- Systems failure causing loss of transaction records or inability to access them as required
- Inappropriate manual intervention or failures in scheduled job processing



SalaCyber Information System Audit (SISA)

21

© 2020 SalaCyber All Rights Reserved

49p search it detailed

How is this controlled?

- Access requests to the application/database/operating system/data file are properly reviewed and authorised by management.
- Terminated application/database/operating system/data file user access rights are removed in a timely basis.
- Super-user/administrative application/database/operating system/data file transactions and activities are periodically monitored for appropriateness.
- Passwords to the application/database/operating system/data file are utilised in an effective manner.
- Access rights to a application/database/operating system/data file are periodically monitored for appropriateness.

1. User Access Requests

Access requests to the application, database, operating system, or data files are controlled through a **formal access request process**. Users submit documented access requests, which are **reviewed and approved by management** (such as the system owner or department head) prior to access being granted. Evidence of approval is retained for audit purposes.

2. Removal of Terminated User Access

User access rights for terminated or transferred employees are **revoked in a timely manner** based on notifications received from Human Resources or management. The IT team performs **de-provisioning procedures** immediately upon termination, and periodic checks are conducted to ensure no inactive or unauthorized accounts remain.

3. Monitoring of Super-User / Administrative Access

Super-user or administrative activities are **restricted to authorized personnel only** and are subject to **periodic monitoring**. System logs and audit trails are reviewed by management or an independent party to ensure that administrative activities are **appropriate, authorized, and aligned with job responsibilities**.

4. Password Management

Passwords for applications, databases, operating systems, and data files are **configured according to security policy requirements**. This includes minimum password length, complexity, expiration, and retry limits. Password usage is enforced through system configuration, and users are required to comply with the established password policy.

5. Periodic Review of Access Rights

Access rights to applications, databases, operating systems, and data files are **periodically reviewed by management** to confirm that user access remains **appropriate and consistent with job roles**. Any unnecessary or excessive access identified during the review is promptly removed.

Audit Conclusion

These controls ensure that **logical access is appropriately authorized, monitored, and restricted**, thereby reducing the risk of unauthorized access, data misuse, or security breaches.

68p 4 control domain 2

How is this controlled?

- Data is appropriately backed up and recoverable (Incremental backup or full backup) Hard Disk/Tape
- Only approved and tested changes are made to the batch scheduler (run EOD)
- Errors in production processing are identified and resolved
- Physical security measure are in place (Data center Equipment ? Access Control? Who has permission?)

How Is This Controlled? (IT Operations Controls)

1. Data Backup and Recovery

Data is protected through **regular backup procedures**, including **incremental and full backups**, which are performed according to an established backup schedule. Backups are stored on **secure media such as hard disks or tapes**, and recovery procedures are **periodically tested** to confirm that data can be restored when required. Backup logs and test results are reviewed by management.

2. Batch Scheduler Changes (End-of-Day Processing)

Changes to the batch scheduler, including End-of-Day (EOD) processing, are controlled through a **formal change management process**. All changes must be **requested, approved, tested, and documented** prior to implementation in the production environment. Only **authorized personnel** are permitted to make changes, and management reviews change records for completeness and approval.

3. Production Processing Error Handling

Errors occurring during production processing are **automatically logged and monitored** by the system or operations team. Identified errors are **investigated, documented, and resolved in a timely manner**, and corrective actions are reviewed by management. Exception reports and incident records are retained for audit review.

4. Physical Security Controls

Physical security measures are implemented to **protect data center facilities and equipment**. Access to the data center is **restricted to authorized personnel only** using controls such as **access cards, biometric systems, or security logs**. Entry and exit activities are **monitored and reviewed**, and visitors are required to obtain approval and be escorted. Physical access rights are **periodically reviewed by management**.

Audit Conclusion

These controls ensure the **availability, integrity, and security of systems and data**, reducing the risk of data loss, unauthorized changes, processing errors, and physical security breaches.



How is this controlled?

- Data is appropriately backed up and recoverable (Incremental backup or full backup) Hard Disk/Tape
- Only approved and tested changes are made to the batch scheduler (run EOD)
- Errors in production processing are identified and resolved
- Physical security measure are in place (Data center Equipment ? Access Control? Who has permission?)

SalaCyber Information System Audit (SISA) 68 © 2020 SalaCyber All Rights Reserved

71-82 domain 3 program change

4.6. Program Change

To ensure that changes to programs and related infrastructure components are requested, authorised, prioritised, performed, tested, and implemented in accordance with management's objectives.

1. Configuration Change

Meaning

A **configuration change** is a change to **system settings or parameters** without changing the program source code.

Examples

- Changing password policy settings (length, expiry)
- Modifying firewall rules
- Updating database connection settings
- Changing batch scheduler timing (EOD run time)

Audit focus

- Approval required
- Change documented
- Tested before applying to production
- Access restricted to authorized staff

2. Code Change

Meaning

A **code change** is a modification to the **source code written by developers**.

Examples

- Fixing a bug in an application
- Adding validation to prevent incorrect data entry
- Enhancing a report calculation
- Updating SQL queries in the program

Audit focus

- Formal change request
- Development and testing in non-production environment
- Code review and approval
- Version control used

3. Program Change

Meaning

A **program change** is a **broader term** that includes **any change that affects how a program runs**, including code changes or replacing programs.

Examples

- Deploying a new version of an application
- Replacing an old payroll program
- Modifying batch programs used for EOD processing
- Applying patches or updates that alter program behavior

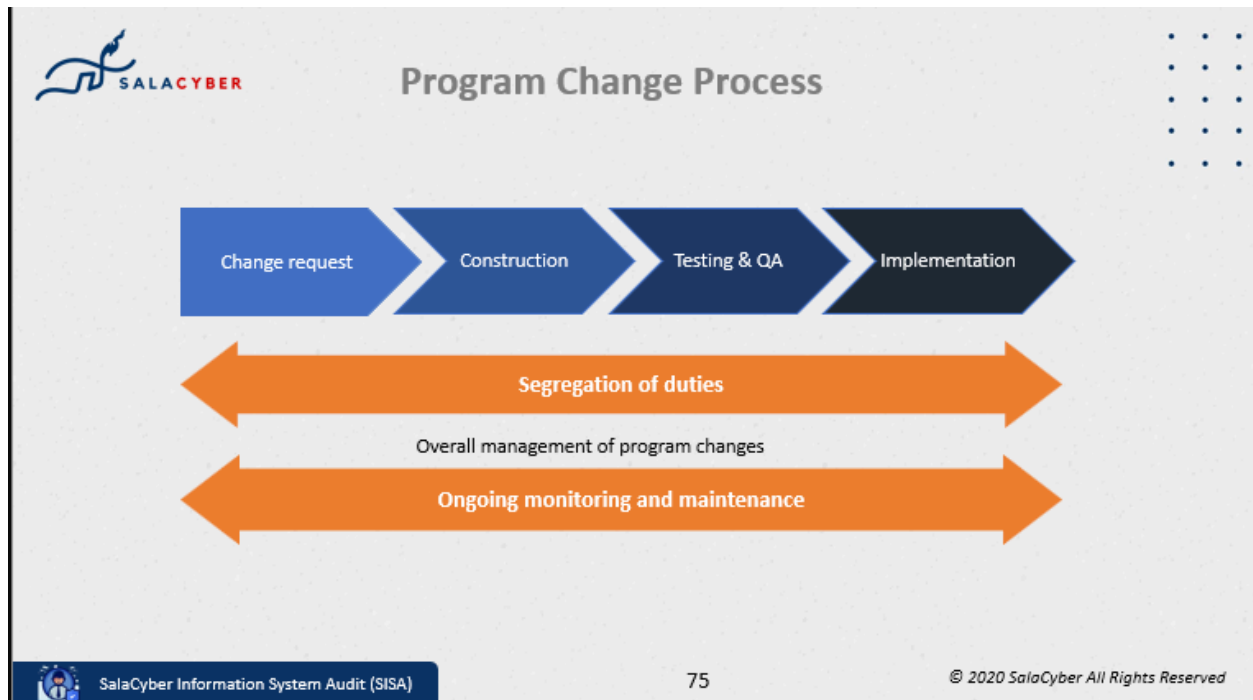
Audit focus

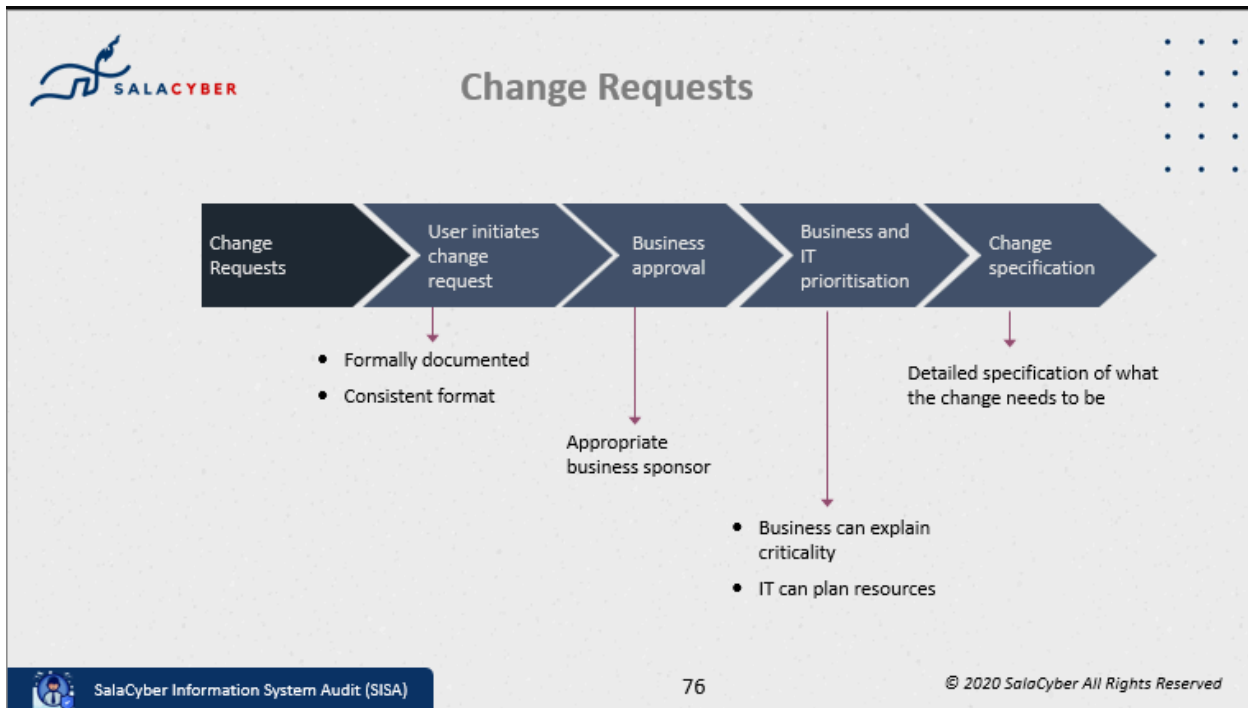
- Change management process followed
- Testing evidence available
- Management approval before deployment

What are the risks of performing change ?

- Unauthorised changes to application code, by passing change control
- Changes that introduce errors into applications
- Unauthorised direct changes to application configuration settings, bypassing change control

- Failure to make changes needed to reflect a regulatory or accounting policy change
- Changes to the IT environment (Operating System) are likely to cause problems in the application





Changes not requiring business approval

Infrastructure changes:

- Business may not know they are needed
- Business users may not be able to complete the change request as they may not understand the implications of the change, and the priority
- Should still be formally requested and approved – by IT

- Need to be considered for prioritisation alongside all other changes.

Emergency changes

- Often sent out by vendors of applications/operating systems when a bug is found
- Need to be implemented quickly to keep systems running
- May not have time to go through the formal change request process before implementation
- Should be retrospectively approved



Construction



- Developers program the changes in line with specifications
- Application code changes should always be done in a development environment
- There may be some types of changes which can only be made directly in production (e.g. data fix, some configuration changes)
- Controls within the development environment to ensure version control

 SalaCyber Information System Audit (SISA)

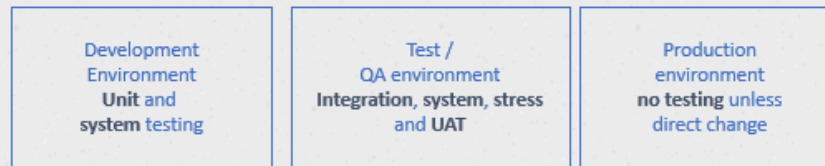
78

© 2020 SalaCyber All Rights Reserved

Testing and QA



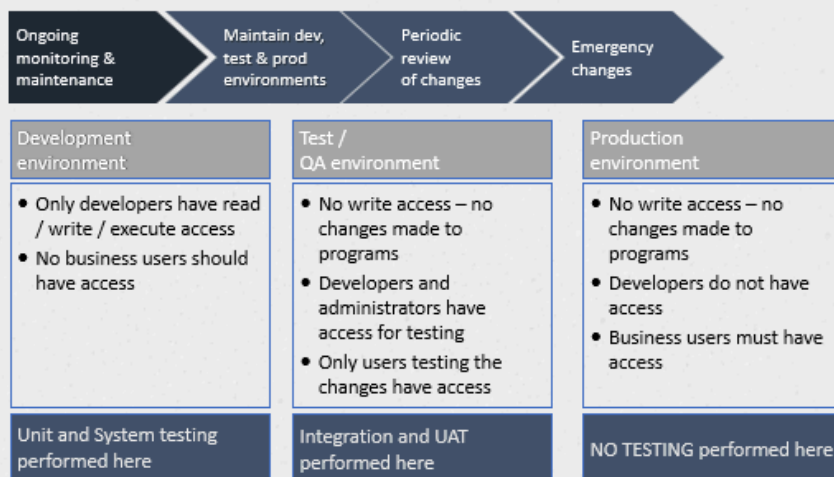
- **Unit** testing – does the changed program work on its own?
- **System** testing – does the changed program work within the system?
- **Integration** testing – does the change work with other applications, reports, data?
- User acceptance testing (**UAT**) – does the change meet the users requirements?
- **Regression** testing – did additional errors arise from fixing other problems?
- **Stress** testing – does it operate reliably for significant number of transactions?



Implementation



- Were the original change requests appropriately authorised?
- Has all necessary testing has been performed and signed off?
- Developers should not be able to migrate changes to the live environment.



How is this controlled?

- Changes to application programs are adequately tested and approved before being migrated into production
- Development, testing and production environments are segregated for changes to application programs
- Changes to application configurations are adequately tested and approved before being migrated into production
- Development, testing and production environments are segregated for changes to application configurations
- Changes to databases are adequately tested and approved before being migrated into production
- Development, testing and production environments are segregated for changes to databases (Oracle Database)
- Changes to the operating system/network adequately tested and approved before being migrated into production

How Is This Controlled? (IT Change Management Controls)

1. Change Request and Approval

All changes to application programs, application configurations, databases (including Oracle Database), and operating system/network components are initiated through a **formal change request**. Each request is **reviewed, risk-assessed, and approved by management** before any implementation occurs.

2. Testing Prior to Production Migration

Changes are **developed and tested in a non-production environment** to verify functionality, security, and performance. Evidence of testing (such as test results or sign-off) is documented and reviewed prior to migration into production.

3. Segregation of Environments

Development, testing, and production environments are logically and/or physically segregated. Developers are restricted from accessing the production environment, and only **authorized personnel** are permitted to migrate approved changes.

4. Controlled Migration to Production

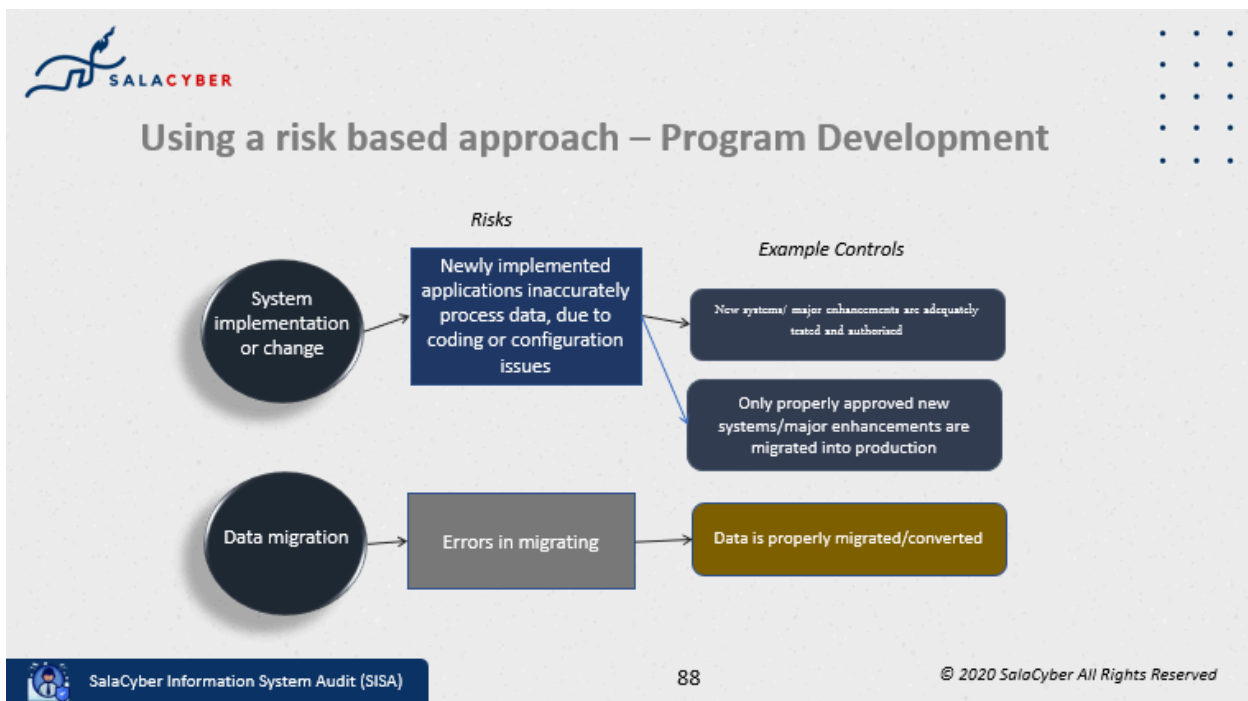
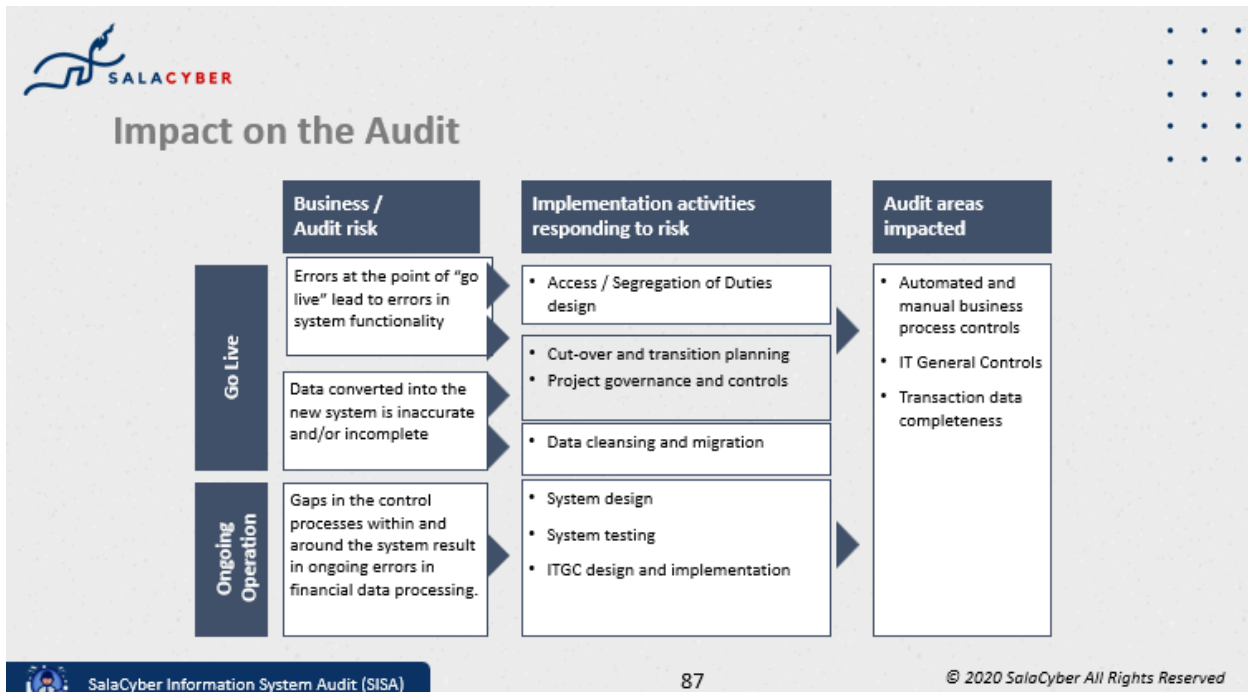
Only **tested and approved changes** are migrated into the production environment. Migration is performed by authorized IT personnel following documented procedures, and implementation activities are logged for audit purposes.

5. Access Control and Monitoring

Access to production systems, applications, databases, and network devices is **restricted and monitored**. Change logs, system logs, and audit trails are periodically reviewed to detect unauthorized or unapproved changes.

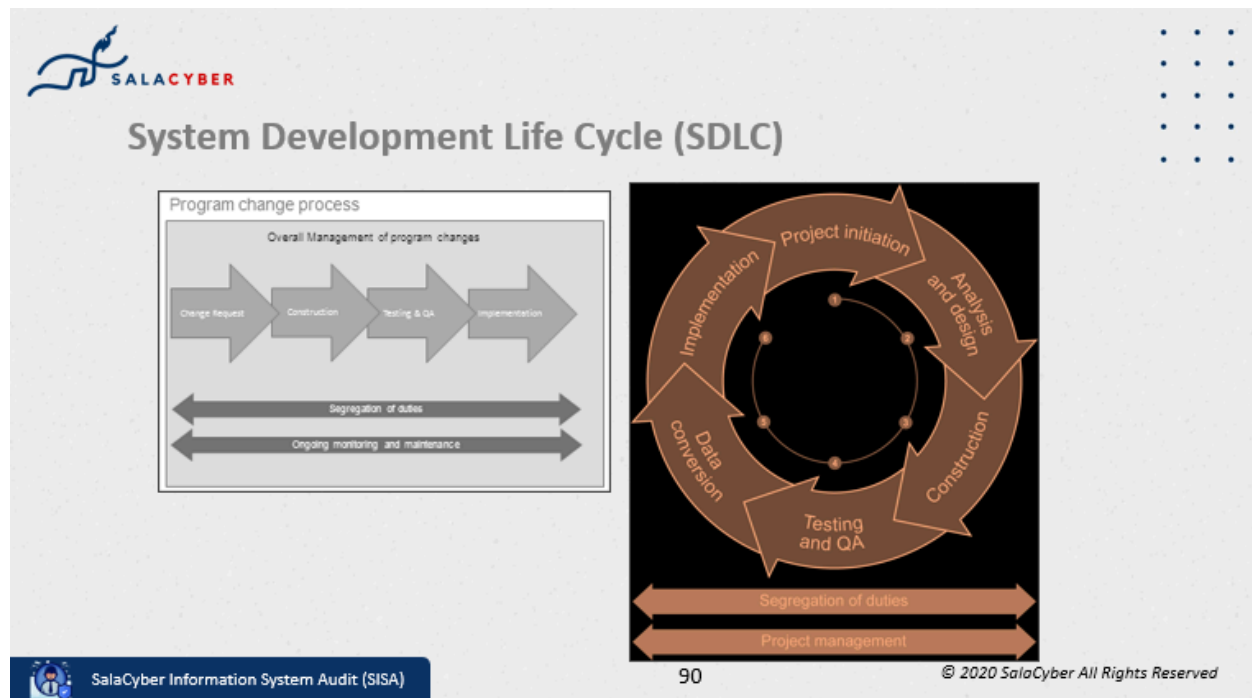
Audit Conclusion

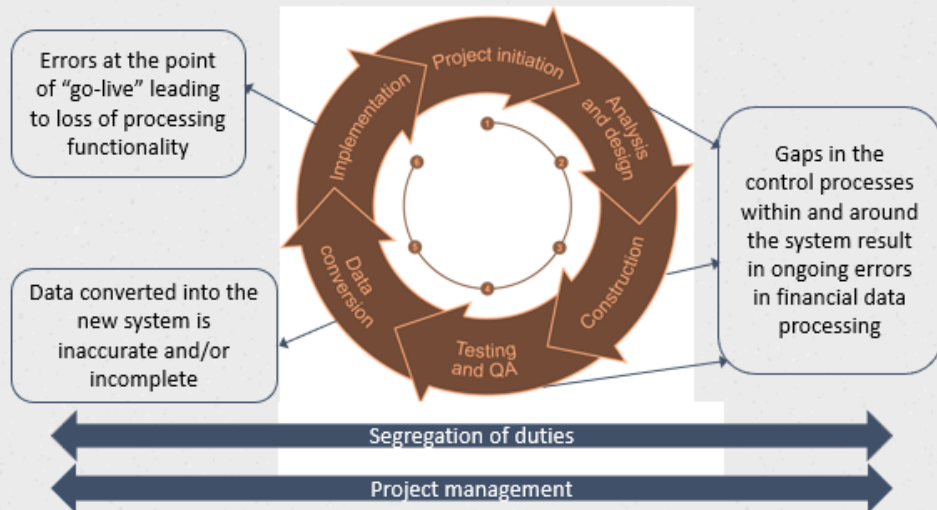
These controls ensure that **all changes are properly authorized, tested, and implemented in a controlled manner**, reducing the risk of unauthorized changes, system failures, and data integrity issues.



System Development Life Cycle (SDLC)

- SDLC is a generic methodology for system implementations
- It acts as a framework to identify the key activities at different stages of the implementation, and related risks and controls
- Key points to note in relation to SDLC:
 - Stages are not all sequential (e.g. data conversion processes should commence early in the process).
 - It relates to IT system implementation / development (i.e. not a broader project management framework).





Project Initiation

What happens at this stage ?

- Where projects are
 - Defined
 - Prioritised
 - Approved
- Much more complex than program changes
- Should have formal policies and procedures for project initiation
- Unlikely to be a key stage from an audit perspective

Example controls

- Identification of all relevant stakeholders and approval from them for initiation.
- Related documents such as
 - FSD (Functional Specification Document)
 - Contract/Agreement
 - SLA (Service Level Agreement)
 - Timelines
 - Project charter
 - Non-disclosure agreement (NDA)

Data Conversion

What happens at this stage ?

- Converts data from old system to new system.
- Can directly impact financial data.
- May involve data cleansing, use of staging areas and migration tools.
- May involve a number of test loads.

Example controls:

- Formal mapping of old to new data, that is automatically applied to all records
- Record counts
- Sample testing
- Exception reporting
- Test conversion prior to UAT
- Change request

Implementation

What happens at this stage ?

- Same principles as program changes.
- Implementation by authorised personnel, not by developers.
- “Go Live” decision
- Back-out procedures
- Scheduled implementation

Example controls:

- Final approval of go-live by steering committee / key stakeholders.
- Assessment of project against “go-live criteria”.
- Approval of post go-live remediation plan.

4.7. Program Development

What are some of the reasons why businesses initiate program development ?

- New systems/ major enhancements are adequately tested and authorised.
- Only properly approved new systems/major enhancements are migrated into production.
- Data is properly migrated/converted.

98 3control of program development control 4

ITGC 4 domain 19 control

start exam 8:15